INFORME DE RESULTADOS No. 2

RETEST DE ESCENARIOS DE PRUEBA QA — GRUPO 2

Proyecto: UDV — Sistema de Gestión Académica
Módulo: API y Seguridad
Grupo evaluado: Grupo 2
Período de evaluación: 23 y 24 de octubre de 2026
Documento de referencia: Updt 2 – Escenarios de Prueba
Tipo de evaluación: Retest funcional, seguridad, autorización e integración

---

1. Objetivo

Documentar los resultados del segundo proceso de retest del Grupo 2, verificando las correcciones realizadas sobre los hallazgos anteriores y evaluando el comportamiento actual de la API en materia de autenticación, autorización, gestión de usuarios, archivos, validación de datos, manejo de errores y auditoría.

La evaluación busca determinar qué escenarios cumplen sus criterios de aceptación, cuáles presentan defectos y qué aspectos requieren seguimiento antes de la integración definitiva del módulo.

2. Resumen ejecutivo

Durante el segundo retest se evaluaron los 38 escenarios incluidos en la matriz de QA del Grupo 2, distribuidos entre prioridades alta, media y baja.

Los resultados muestran avances importantes respecto de la evaluación inicial. Se comprobó la corrección de varios problemas relacionados con autenticación JWT, restricciones por roles, acceso a endpoints protegidos, consulta de usuarios y manejo de errores HTTP.

También se verificó el funcionamiento de la revocación de sesiones, el rechazo de tokens vencidos o alterados, la validación de archivos y el bloqueo temporal por intentos fallidos de inicio de sesión.

Sin embargo, se identificaron dos escenarios fallidos, una validación parcial y un escenario cuyo retest no pudo completarse.

Resultados generales

Estado	Cantidad
PASS	34
FAIL	2
PARCIAL	1
PASS histórico, retest pendiente	1
Total	**38**

Los resultados reflejan un avance satisfactorio en las funcionalidades evaluadas, aunque todavía existen problemas que deben corregirse antes del cierre completo del módulo.

3. Resultados de prioridad ALTA

3.1. Autenticación y manejo de sesiones

Escenarios: G2-01, G2-02, G2-05 y G2-06.

Se confirmó que el inicio de sesión con credenciales válidas devuelve HTTP 200 y genera un JWT funcional. El token permite acceder al endpoint protegido `/api/v1/me` y recuperar la identidad y los permisos correspondientes.

Asimismo, se verificó que las contraseñas incorrectas son rechazadas con HTTP 401 y que el cierre de sesión revoca el token, impidiendo reutilizarlo posteriormente.

También se comprobó que los endpoints protegidos rechazan solicitudes sin autenticación.

Resultado: PASS.

3.2. Permisos y autorización

Escenarios: G2-08, G2-09, G2-10 y G2-17.

Se verificó que un usuario con rol docente no puede ejecutar funciones reservadas para administradores.

Las solicitudes no autorizadas devolvieron HTTP 403 y no expusieron información protegida.

Adicionalmente, se intentó falsificar el encabezado `usuario-actual` para acceder a funciones administrativas. El backend continuó aplicando los permisos asociados al JWT, rechazando la operación.

También se comprobó que un docente no podía modificar la cuenta de un administrador mediante la manipulación del identificador del usuario.

Resultado: PASS.

Estos resultados representan una mejora importante frente a los hallazgos iniciales de integración y autorización.

3.3. Seguridad de entradas

Escenarios: G2-15 y G2-16.

Se realizaron pruebas de Cross-Site Scripting (XSS) y SQL Injection.

En la prueba XSS, el contenido introducido se almacenó, pero no se ejecutó como código en la pantalla evaluada. Posteriormente, el valor de prueba fue restaurado.

En la prueba de SQL Injection, la API rechazó el intento de autenticación y no permitió evadir los controles de acceso.

Resultado: PASS en los casos evaluados.

Estas pruebas no constituyen una evaluación exhaustiva de todas las posibles variantes de XSS o SQL Injection.

3.4. Seguridad de archivos

Escenarios: G2-19, G2-20, G2-21 y G2-22.

Se comprobó que el sistema rechaza archivos con tipos no permitidos, incluso cuando se modifica su extensión para aparentar que son PDF.

También se confirmó la aplicación de un límite de carga de 5 MB y el rechazo de archivos de mayor tamaño.

Las pruebas de manipulación de rutas no permitieron acceder a archivos internos del servidor.

Sin embargo, se identificó un defecto crítico en el control de acceso a archivos.

G2-21 — FAIL: Acceso no autorizado a archivos de otros usuarios.

Durante el retest, un usuario docente logró descargar un archivo previamente cargado por un administrador. El endpoint respondió HTTP 200 cuando debía rechazar el acceso.

La revisión del código indicó que la ruta exige autenticación, pero no comprueba adecuadamente la propiedad del archivo ni los permisos específicos del solicitante.

Riesgo: posible vulnerabilidad IDOR (*Insecure Direct Object Reference*), que podría permitir el acceso indebido a documentos de otros usuarios.

Acción requerida: implementar validaciones de autorización sobre cada archivo solicitado y repetir el escenario con usuarios de distintos roles.

3.5. Protección de información sensible y tokens

Escenarios: G2-23, G2-24, G2-35, G2-37 y G2-38.

Se verificó que las respuestas de error evaluadas no exponen consultas SQL, contraseñas, tokens ni trazas internas del servidor.

Las respuestas de usuarios incluyen únicamente los campos permitidos.

También se revisaron las reglas de `.gitignore` y los archivos `.env.example`, sin identificar credenciales reales publicadas en los componentes inspeccionados.

Finalmente, se confirmó que los tokens vencidos y los JWT con firmas alteradas son rechazados con HTTP 401.

Resultado: PASS.

4. Resultados de prioridad MEDIA

4.1. Login, identidad y usuarios

Escenarios: G2-03, G2-04, G2-07, G2-11 y G2-12.

Se comprobó que los intentos de inicio de sesión con usuarios inexistentes o campos vacíos son rechazados.

El endpoint `/api/v1/me` devuelve correctamente la identidad, los roles y los permisos del usuario autenticado.

También se verificó la consulta individual de usuarios, el rechazo de accesos sin permisos y la respuesta HTTP 404 al consultar identificadores inexistentes.

Resultado: PASS.

Como observación, la API devuelve HTTP 401 cuando se envían credenciales vacías, mientras que el frontend impide enviar el formulario mediante sus validaciones obligatorias.

4.2. Validaciones y respuestas HTTP

Escenarios: G2-13, G2-14 y G2-25 al G2-30.

Se confirmó el rechazo de solicitudes incompletas y de valores con tipos de datos incorrectos mediante HTTP 422.

La creación válida de usuarios devuelve HTTP 201 y exige autenticación administrativa.

También se comprobaron respuestas HTTP 404 para recursos inexistentes y HTTP 409 cuando se intenta registrar un correo duplicado.

Las respuestas de error evaluadas mantienen una estructura JSON uniforme con los campos `error`, `code`, `message` y `details`.

Resultado: PASS.

4.3. Carga de archivos permitidos

Escenario: G2-18.

Se comprobó que la API acepta un archivo PDF válido, genera un identificador y permite recuperar el documento cargado.

Resultado: PASS.

Observación: Swagger presenta una inconsistencia en la forma de proporcionar el identificador del archivo, utilizando un parámetro de consulta en lugar del parámetro de ruta documentado.

Se recomienda revisar el contrato del endpoint.

4.4. Documentación OpenAPI

Escenario: G2-33.

Resultado: PARCIAL.

Se identificaron inconsistencias entre la documentación Swagger y el comportamiento real de la API.

Entre los problemas observados se encuentran:

- La ausencia de HTTP 409 en la documentación de creación de usuarios.
- Ejemplos de respuestas que muestran valores genéricos `string` en lugar de los objetos JSON reales.
- Diferencias entre los ejemplos documentados de HTTP 422 y el formato de errores implementado.
- La ausencia de HTTP 403 en la documentación del listado de usuarios.

Se observó una mejora en la documentación del error HTTP 401 del endpoint `/api/v1/me`, pero todavía persisten inconsistencias.

Acción requerida: actualizar los esquemas de respuesta y los códigos HTTP documentados para que Swagger represente correctamente el comportamiento real de los endpoints.

5. Resultados de prioridad BAJA

5.1. Paginación de usuarios

Escenario: G2-31.

Resultado: FAIL.

Se verificó que el endpoint `GET /api/v1/users` devuelve directamente un arreglo JSON de usuarios, sin implementar los parámetros ni los metadatos de paginación esperados.

No se identificaron parámetros como `page`, `per_page`, `limit` u `offset` en Swagger.

La respuesta tampoco incluye los campos `page`, `per_page`, `total` y `data` definidos en el escenario.

Acción requerida: implementar paginación funcional, limitar los registros devueltos y agregar los metadatos correspondientes.

5.2. Formato de fechas

Escenario: G2-32.

Resultado: PASS histórico — Retest pendiente.

En una evaluación anterior se había validado el formato ISO 8601.

Durante el retest actual se observó que los endpoints de consulta de usuarios ya no incluyen campos de fecha, aunque estos continúan definidos en el modelo.

Por ello, no fue posible comprobar nuevamente su formato ni la zona horaria.

Acción requerida: confirmar si la exclusión de fechas es un cambio intencional del contrato y definir qué endpoints deben utilizarse para validar este escenario.

No se confirma un defecto funcional.

5.3. Bloqueo temporal por intentos fallidos

Escenario: G2-34.

Se realizaron cinco intentos consecutivos de autenticación con contraseña incorrecta.

Los primeros cuatro devolvieron HTTP 401 y el quinto activó el bloqueo temporal con HTTP 429.

Durante el bloqueo se rechazó incluso una contraseña correcta. Después de transcurrido el período establecido, la cuenta pudo autenticarse nuevamente.

5.4. Auditoría de acciones sensibles

Escenario: G2-36.

Se verificó el registro de eventos de auditoría mediante Swagger y consultas de solo lectura a MySQL.

Durante la prueba con un correo inexistente, la API devolvió HTTP 401 y se confirmó la creación de un evento `LOGIN_FALLIDO` en la tabla `auditoria`.

También se verificó el registro de una modificación de usuario realizada mediante PATCH, identificando la acción, el registro afectado y el administrador responsable.

Resultado: PASS en el entorno evaluado.

Observación de seguimiento: El PM reportó posteriormente que los intentos de login con correos inexistentes no quedan registrados en auditoría. Esto difiere del resultado documentado en el presente retest.

Se recomienda repetir G2-36 en la versión que será integrada a `main`, confirmar la base de datos y la versión de código utilizadas, y determinar si el comportamiento depende del entorno.

6. Hallazgos que requieren seguimiento

ID	Hallazgo	Estado	Prioridad de atención
G2-21	Acceso no autorizado a archivos de otros usuarios	FAIL	Crítica
G2-33	Documentación OpenAPI inconsistente	PARCIAL	Media
G2-31	Paginación de usuarios no implementada	FAIL	Media
G2-32	Formato de fechas sin posibilidad de retest	Pendiente	Baja
G2-36	Diferencia entre el retest de auditoría y el reporte del PM	Verificación adicional	Alta

Aunque G2-31 pertenece a la prioridad BAJA de la matriz original, se recomienda atenderlo durante el siguiente ciclo por tratarse de un comportamiento esperado todavía no implementado.

7. Avances confirmados respecto de la evaluación anterior

El segundo retest permitió confirmar las siguientes mejoras:

1. Funcionamiento de autenticación JWT en endpoints protegidos.
2. Corrección del acceso administrativo mediante encabezados falsificados.
3. Aplicación efectiva de permisos por roles.
4. Disponibilidad de consultas individuales de usuarios.
5. Revocación efectiva de tokens después del logout.
6. Rechazo de tokens vencidos y alterados.
7. Validación de tipos y tamaños de archivos.
8. Respuestas HTTP y estructuras JSON consistentes en los casos evaluados.
9. Funcionamiento del bloqueo temporal por intentos fallidos.
10. Registro de acciones sensibles en auditoría dentro del entorno evaluado.

Estos avances muestran que varias limitaciones identificadas en la evaluación inicial fueron corregidas satisfactoriamente.

8. Recomendaciones para el Grupo 2

Primera prioridad: corregir G2-21. Se recomienda atender de manera inmediata el control de acceso a archivos, ya que el defecto observado puede comprometer la confidencialidad de documentos.

Segunda prioridad: confirmar G2-36. Es necesario aclarar la diferencia entre el resultado de QA y el estado comunicado por el PM, verificando el comportamiento de auditoría en la versión actualizada.

Tercera prioridad: implementar G2-31. El endpoint de listado de usuarios debe cumplir con los parámetros y metadatos de paginación definidos en el escenario.

Cuarta prioridad: corregir G2-33. La documentación OpenAPI debe coincidir con las respuestas reales de la API para facilitar la integración con los demás grupos.

Quinta prioridad: aclarar G2-32. El equipo debe confirmar el contrato actualizado para los campos de fecha y permitir una validación reproducible.

Adicionalmente, se recomienda ejecutar una nueva regresión después de integrar el código del Grupo 2 a `main`.

9. Conclusión

El segundo retest del Grupo 2 evidencia avances significativos en autenticación, autorización, manejo de sesiones, seguridad de tokens, validación de entradas y gestión de usuarios.

De los 38 escenarios evaluados, 34 finalizaron satisfactoriamente, dos presentaron fallos, uno obtuvo resultado parcial y otro conserva una aprobación histórica con retest pendiente.

El hallazgo de mayor impacto corresponde a **G2-21**, debido a que se comprobó la descarga de un archivo perteneciente a otro usuario sin la autorización esperada.

También permanecen pendientes la implementación de paginación, la actualización de la documentación OpenAPI y la aclaración del contrato de fechas.

Respecto de auditoría, el retest documentó un resultado satisfactorio, pero se requiere confirmar su reproducibilidad ante la discrepancia con el reporte posterior del PM.

Resultado general: SATISFACTORIO CON HALLAZGOS PENDIENTES DE CORRECCIÓN.

El Grupo 2 presenta mejoras funcionales y de seguridad importantes, pero no se recomienda cerrar completamente su evaluación hasta corregir los escenarios fallidos y verificar los puntos pendientes en la versión integrada del proyecto.